



ЛЕКЦИЯ 18

Состязательные воздействия на модели: уклонение, возмущения и меры снижения риска

Машинное обучение и безопасность систем

Магистратура НИУ ВШЭ (МИЭМ) · ОП «Информационная безопасность и технологии ИИ»

Автор: Силаев Ю. В. · Время изучения: ≈ 60-70 минут · 52 слайда



О чём эта лекция за одну минуту

Краткая карта того, что вы прочитаете дальше

До сих пор мы считали, что модель ошибается из-за естественных причин: шума в данных, выбросов, сдвига распределения. Эта лекция вводит принципиально иной источник ошибок – целенаправленного противника, который изучает логику модели и специально подбирает вход, чтобы заставить её ошибиться. Такие воздействия называются состязательными (adversarial).

Мы разберём уклонение (evasion) – обман модели в момент применения; запишем формулу простейшей атаки FGSM и увидим, что это тот же градиент, на котором модель обучалась, только развёрнутый против неё. Поймём идею итеративной атаки PGD, допущения о доступе противника (white/gray/black-box) и переносимость атак. Завершим тем, какие меры снижают риск – и почему ни одна из них не является универсальной «серебряной пулей».

Ключевая мысль: надёжность модели – это не только устойчивость к случайностям, но и устойчивость к намеренным воздействиям, которые нужно описывать математически точно.



Откуда мы пришли: природа против противника

Связь с предыдущей лекцией L17 – устойчивость к шуму и сдвигу данных

Лекция L17 заканчивалась мыслью-мостом: модель может деградировать оттого, что среда меняется сама по себе – шум, выбросы, сдвиг распределения, новые объекты. Никто не действует злонамеренно. L18 переходит на другую сторону этого моста: теперь у входных данных появляется автор, и этот автор враждебен.

L17 · ПРИРОДА

- Среда меняется сама
- Шум, выбросы, дрейф, OOD
- Источник ошибки случаен
- Меры: augmentation, переобучение, обновление признаков

L18 · ПРОТИВНИК

- Вход меняет враг намеренно
- Evasion, FGSM, PGD, transfer
- Источник ошибки оптимизирован под модель
- Меры: hardening, ансамбли проверок, fallback

Вместе L17 и L18 образуют двухкомпонентную модель угроз для ML: «природа» и «противник».



Чему вы научитесь

Учебные результаты

ВЫ НАУЧИТЕСЬ

1. объяснять, что такое состязательное воздействие – и концептуально, и формально;
2. уверенно отличать естественную ошибку и шум от целенаправленного adversarial-воздействия;
3. записывать формулу FGSM-возмущения и объяснять смысл каждого её компонента;
4. понимать идею PGD как итеративного развития FGSM в пределах ϵ -окрестности;
5. различать допущения white-box, gray-box и black-box о доступе противника к модели;
6. объяснять, почему высокая точность на тесте не гарантирует устойчивости к атаке;
7. формулировать базовые меры снижения риска и понимать, почему «серебряной пули» нет;
8. отличать исследовательскую демонстрацию уязвимости от пригодной к эксплуатации атаки.



Что нужно знать до начала

Предварительные требования и связи с предыдущими лекциями курса

Лекция опирается на материал, уже пройденный в курсе. Если какой-то пункт ниже вызывает затруднение, вернитесь к указанной лекции – без этой базы FGSM покажется «магией», хотя на самом деле это прямое применение знакомого вам градиента.

Устойчивость моделей, дрейф, модель угроз «природа»

L17

Градиент функции потерь и цепное правило (chain rule)

L06 · L13

Обучение нейросети и обратное распространение

L13

Метрики качества, цена ошибок и выбор порога

L04 · L07

ML-модель как компонент системы, а не «умный блок»

L03

Градиент, который мы используем для атаки в этой лекции, – тот же, что в L06.



План лекции

Семь частей · 52 слайда · ≈ 60-70 минут изучения

1	Введение	слайды 1-6	~8 мин
2	Мотивация: зачем это инженеру ИБ	слайды 7-11	~6 мин
3	Основное содержание: воздействие, FGSM, допущения, меры	слайды 12-38	~33 мин
4	Связки с практикой ИБ	слайды 39-44	~8 мин
5	Итоги и навигация по курсу	слайды 45-48	~5 мин
6	Источники для углубления	слайды 49-50	~3 мин
7	Глоссарий	слайды 51-52	~3 мин



Зачем это инженеру по безопасности

Модель защиты сама становится мишенью – и противник это знает

В задачах ИБ ML-модель почти всегда стоит на границе между атакующим и защищаемой системой: почтовый фильтр, детектор вторжений, антифрод, классификатор вредоносных файлов. У неё есть особенность, которой нет у прогноза погоды: по другую сторону входа сидит заинтересованный противник, который хочет, чтобы модель ошиблась в его пользу.

Это меняет правила. Противник наблюдает за реакциями системы, выясняет её логику и подбирает вход, который проходит проверку. Он не ждёт, пока «природа» сменит распределение, – он сам конструирует наихудший для модели случай. Поэтому средней точности мало: нужно понимать, как модель ведёт себя против того, кто активно ищет её слабые места.

Противник адаптируется

подстраивается под известную логику модели

Защита – это объект атаки

сама модель становится целью, а не просто инструментом

Цена ошибки высока

один пропуск = успешное вторжение или утечка



Мотивирующий кейс: уклонение от детектора

Сквозной датасет курса – CIC-IDS-2018

CIC-IDS-2018 · ЧТО ЭТО

Публичный датасет сетевого трафика, сквозной пример курса. Около 16 млн flow-записей за 10 дней, 80 признаков на соединение (длительность, число пакетов, размеры, флаги и т. д.), 14 типов атак плюс класс Benign (нормальный трафик). Мы уже встречали его при разборе метрик и моделей; теперь посмотрим на него глазами противника.

Представьте детектор сетевых вторжений, обученный на CIC-IDS-2018: он отделяет вредоносные соединения от нормальных и на тесте показывает высокую точность. Теперь на сцену выходит противник. Его цель – провести атакующее соединение так, чтобы детектор пометил его как Benign.

Идея уклонения: не меняя сути атаки, противник слегка подкручивает наблюдаемые признаки соединения – удлиняет паузы, дробит трафик на большее число пакетов – оставаясь в пределах работающей атаки, но смещая признаки в область, которую модель считает «нормальной».



Почему точность на тесте обманчива

Высокое качество на тесте $\neq$ устойчивость к противнику

Стандартная оценка измеряет качество на тестовой выборке из того же распределения, что и обучающая. Она отвечает на вопрос: «как часто модель ошибается на типичных данных?». Adversarial-сценарий задаёт другой вопрос: «существует ли близкий к реальному вход, на котором модель ошибётся, и легко ли его найти?». Это про наихудший случай, а не про средний.

ОБЫЧНЫЙ ТЕСТ

- Вопрос: ошибки на типичных данных?
- Данные из того же распределения
- Метрика среднего случая
- Ничего не знает о противнике

ADVERSARIAL-СЦЕНАРИЙ

- Вопрос: есть ли вход, ломающий модель?
- Вход подобран целенаправленно
- Метрика наихудшего случая
- Прямо моделирует противника

Модель может иметь 99 % точности на тесте и при этом ошибаться почти всегда, когда вход подобран специально.



Что происходит без учёта противника

Типовые провалы реальных систем, не закладывавших adversarial-пуск

Если инженер не держит в голове модель угроз с противником, система выглядит надёжной на бумаге, но даёт сбой в эксплуатации. Ниже – повторяющийся сценарий деградации защиты, который встречается на практике снова и снова.

1

Слепое доверие одной модели – Решение детектора принимается автоматически, без второй проверки и без участия человека.

2

Нет порога подозрительности – Система не отслеживает входы, подозрительно близкие к границе решения.

3

Противник пробует и учится – Многократно зондируя систему, атакующий находит вход, который проходит как нормальный.

4

Тихий обход без сигнала – Атака проходит, метрики на обычном тесте остаются прекрасными – провал никто не замечает.



Частая ошибка: «adversarial – это экзотика»

Разберём заблуждение прямо на входе в тему

⚠ ЧАСТАЯ ОШИБКА

«Состязательные атаки – это академические трюки с картинками: пиксели подкрутили, нейросеть увидела гиббона вместо панды. К реальным системам безопасности с табличными признаками и логами это отношения не имеет».

ПОЧЕМУ ЭТО НЕВЕРНО

Тот же механизм работает на любых признаках. Уклонение от детектора вторжений, обход спам-фильтра подбором формулировок, маскировка вредоносного файла под легитимный – это всё та же идея: малое допустимое изменение входа смещает решение модели. Картинка с пандой – лишь наглядная демонстрация, а не граница применимости.

Считать adversarial ML экзотикой – значит оставить в системе защиты слепое пятно ровно там, где сидит противник.



БЛОК 3.1

3.1

Что такое состязательное воздействие

Сначала договоримся о понятиях: что именно мы называем adversarial-возмущением, чем оно отличается от случайного шума и что значит «уклонение» (evasion). Формулу FGSM разберём в следующем блоке – здесь только смысл.



Состязательное возмущение: определение

Вводим центральное понятие лекции

ОПРЕДЕЛЕНИЕ

Состязательное возмущение (adversarial perturbation) – малое изменение δ входного объекта x , намеренно подобранное так, чтобы изменить предсказание модели, при этом δ удерживается в пределах ϵ -окрестности исходного входа (обычно по норме L^∞ или L_2).

Распакуем определение. «Малое» означает, что возмущённый вход $x' = x + \delta$ для человека или системы практически неотличим от исходного: пакет остаётся валидным, файл – рабочим, текст – читаемым. «Намеренно подобранное» отличает adversarial-возмущение от случайного шума: δ не случайно, а вычислено против конкретной модели. « ϵ -окрестность» – это формальная граница допустимого изменения: насколько далеко противнику разрешено отойти от исходного входа.



Шум, выброс и воздействие – это разные вещи

Граница с L17: случайность против намерения

Все три описывают «необычный» вход, но различаются источником. Первые два – из L17 (среда меняется сама). Adversarial-воздействие качественно иное: за входом стоит оптимизация против модели.

ТИП	ЧТО ЭТО	ИСТОЧНИК	ГДЕ В КУРСЕ
Случайный шум	Мелкие случайные отклонения признаков	Случаен, ненаправлен	L17 · природа
Выброс / OOD	Объект из другой области пространства	Случаен или редок	L17 · природа
Adversarial-воздействие	Малое δ , вычисленное против модели	Оптимизирован под ошибку	L18 · противник

Ключевое различие – не размер изменения, а его источник: природа действует вслепую, противник целится.



Частая ошибка: «это просто шум»

Почему случайность и намерение нельзя смешивать

⚠ ЧАСТАЯ ОШИБКА

«Если модель устойчива к случайному шуму на входе, значит, она устойчива и к атаке – ведь возмущение тоже маленькое».

Почему это не так. Устойчивость к случайному шуму усредняется по всем направлениям: большинство случайных сдвигов модель переживает спокойно. Но противник не ходит случайно – он выбирает именно то направление, в котором модель наиболее уязвима. В многомерном пространстве признаков такое «плохое» направление почти всегда существует, даже если средняя устойчивость к шуму высокая. Поэтому тест на случайный шум не говорит ничего о стойкости к атаке.

Аналогия: случайный шум – это рябь на воде со всех сторон; атака – это один точный удар в единственную трещину.



Уклонение (evasion): определение

Класс атак, которому посвящена эта лекция

ОПРЕДЕЛЕНИЕ

Уклонение (evasion) – воздействие на вход модели в момент её применения (на этапе инференса), цель которого – заставить уже обученную модель выдать нужное противнику решение, не меняя саму модель.

Где в жизненном цикле модели. Это важно зафиксировать сразу: evasion работает уже после обучения, с готовой моделью, и трогает только вход. Противник не имеет доступа к обучающим данным и не меняет веса – он лишь подаёт специально подобранный объект. Этим evasion принципиально отличается от отравления обучающих данных (poisoning), которое мы разберём отдельно в L19.

Обучение данные → веса

Модель готова веса зафиксированы

Инференс здесь работает evasion



Мини-резюме: что мы разобрали

Блок 3.1 – понятийная база перед формулой FGSM

Состязательное возмущение – малое намеренное δ в ϵ -окрестности входа, меняющее предсказание модели.

Не шум и не выброс – отличие не в размере изменения, а в источнике – за δ стоит оптимизация против модели.

Случайная устойчивость $\neq$ стойкость к атаке – противник бьёт в худшее направление, а не усредняется по всем.

Evasion – воздействие на вход на этапе инференса; модель и обучающие данные не трогаются.



БЛОК 3.2

3.2

FGSM: как вычисляется возмущение

Теперь – математика. Запишем простейшую атаку формулой и увидим, что она использует тот же градиент, на котором обучалась модель. Это ядро лекции и прямой вопрос экзамена. Идею PGD и числовой пример разберём во второй части блока.



От градиента обучения к градиенту атаки

FGSM – это знакомый вам градиент, развёрнутый против модели

Вспомним обучение (как в L06 и L13). Чтобы обучить модель, мы считаем градиент функции потерь по весам, $\nabla_w L$, и делаем шаг против него – так потеря уменьшается, и модель учится. Градиент показывает направление наибо́льшего роста потери; мы идём в обратную сторону.

Атака меняет две вещи. Во-первых, берём градиент не по весам, а по входу: $\nabla_x L$. Веса модели зафиксированы (модель уже обучена), а варьируем мы вход. Во-вторых, идём не против градиента, а вдоль него – туда, где потеря растёт. Иначе говоря, мы делаем ровно противоположное обучению: не «как изменить модель, чтобы она была права», а «как изменить вход, чтобы она ошиблась».

Обучение

$\nabla_w L$ · шаг против градиента · меняем веса

Атака (FGSM)

$\nabla_x L$ · шаг вдоль градиента · меняем вход



Формула FGSM

Fast Gradient Sign Method – одношаговое возмущение

ФОРМУЛА

$$x' = x + \epsilon \cdot \text{sign}(\nabla_x L(f(x), y))$$

Что говорит формула. Возьми исходный вход x . Посчитай градиент потери по входу $\nabla_x L$ – он указывает, в какую сторону менять каждую координату, чтобы потеря выросла. Возьми только знак этого градиента по каждой координате, умножь на маленький бюджет ϵ и прибавь к x . Получишь возмущённый вход x' – внешне почти такой же, но уводящий модель в ошибку. Это один шаг, поэтому метод и называется «быстрым».

Тот же ∇L , что в обучении (L06, L13) – но по входу x , а не по весам, и со знаком «плюс».



Разбор компонентов FGSM

Каждый символ формулы – и что он значит

x	исходный вход модели (объект, который атакуют)
y	истинная метка x (нужна, чтобы знать, в какую сторону «портить»)
$f(x)$	выход модели на входе x
$L(f(x), y)$	функция потерь: насколько предсказание расходится с y
$\nabla_x L$	градиент потерь по входу: куда двинуть x , чтобы потеря выросла
$\text{sign}(\cdot)$	знак по каждой координате: фиксированный шаг ± 1 , не величина
ϵ	бюджет возмущения: максимальный сдвиг по координате (размер ϵ -шара)
x'	возмущённый вход $x + \delta$, где $\delta = \epsilon \cdot \text{sign}(\nabla_x L)$



Почему sign и почему ϵ

Две детали, которые делают FGSM «дешёвым» и контролируемым

SIGN(·) – ТОЛЬКО ЗНАК

Градиент имеет и направление, и величину. FGSM выбрасывает величину и берёт лишь знак по каждой координате. Это значит: по каждому признаку делаем фиксированный шаг ровно $\pm\epsilon$, независимо от того, насколько круто там растёт потеря. Так возмущение гарантированно остаётся внутри L^∞ -шара радиуса ϵ (ни одна координата не сдвинется больше чем на ϵ) и считается за один проход – отсюда «fast».

ϵ – БЮДЖЕТ ВОЗМУЩЕНИЯ

ϵ задаёт, насколько далеко противнику разрешено отойти от исходного входа. Маленькое ϵ – возмущение незаметно, но сбить модель труднее; большое ϵ – атака мощнее, но изменение перестает быть «малым» и может разрушить сам объект (невалидный пакет, нечитаемый текст). По сути ϵ – это формализация допустимых модификаций: в трафике можно менять длительность и число пакетов, но не самую полезную нагрузку.



Частая ошибка: «FGSM – это магия»

Самое частое заблуждение по этой теме на экзамене

⚠ ЧАСТАЯ ОШИБКА

«В формуле FGSM есть что-то загадочное: модель сама подсказывает, как её обмануть. Это особый хитрый приём, отдельный от обычного обучения».

ПОЧЕМУ ЭТО НЕВЕРНО

Никакой магии – это то же цепное правило (chain rule). Чтобы обучать модель, фреймворк и так считает ∇L обратным распространением. FGSM просто запрашивает у того же механизма градиент по входу вместо градиента по весам – одна строчка в коде. «Модель подсказывает, как себя обмануть» – это свойство не атаки, а любой дифференцируемой модели: она всюду сообщает направление роста потери.

Поняли обратное распространение в L13 – значит, поняли механику FGSM: это не новый метод, а новый адресат градиента.



Идея PGD: итеративный FGSM

Projected Gradient Descent – на уровне принципа

FGSM делает один шаг. Одношаговое возмущение грубое: оно может перелететь цель или упереться в нелинейность модели. Естественное улучшение – делать много маленьких шагов FGSM подряд, каждый раз пересчитывая градиент в новой точке. Это и есть PGD.

1 · ШАГ

Маленький шаг FGSM с размером α (α меньше ϵ): $x \leftarrow x + \alpha \cdot \text{sign}(\nabla_x L)$

2 · ПРОЕКЦИЯ

Если вышли за ϵ -шар вокруг исходного x – возвращаем (проецируем) обратно на границу

3 · ПОВТОР

Повторяем шаги 1-2 заданное число раз; градиент каждый раз свежий

Зачем «проекция». Шаги накапливаются, но возмущение всё равно обязано остаться внутри ϵ -окрестности (бюджет противника не вырос). Проекция на каждом шаге возвращает x внутрь ϵ -шара. PGD считается базовой эталонной атакой: устойчивость к нему – типичная проверка adversarial-надёжности.



Числовой микропример FGSM

Один шаг по двум признакам соединения (схема CIC-IDS-2018)

Условие. Детектор различает Benign и Attack по двум нормированным признакам соединения. Берём атакующий объект x и бюджет $\epsilon = 0.10$. Знаки градиента потери по входу: $\text{sign}(\nabla_x L) = (+1, -1)$.

ПРИЗНАК	x	$E \cdot \text{SIGN}$	$x' = x + E \cdot \text{SIGN}$
Длительность потока	0.62	+0.10	0.72
Доля коротких пакетов	0.48	-0.10	0.38

Что произошло. Каждый признак сдвинулся ровно на $\epsilon = 0.10$ в сторону, увеличивающую потерю – в направлении знака градиента. Изменения крошечные и остаются в пределах допустимых модификаций соединения, но вектор x' переходит границу решения, и детектор теперь относит объект к Benign. Сама атака не изменилась – изменилось лишь то, как её видит модель.



Мини-резюме: FGSM и PGD

Блок 3.2 – формульное ядро лекции

FGSM – $x' = x + \epsilon \cdot \text{sign}(\nabla_x L)$ – одношаговое возмущение по знаку градиента потери.

Тот же градиент – что в обучении (L06, L13), но по входу x и вдоль роста потери, а не против.

sign и ϵ – sign даёт фиксированный шаг и держит δ в L^∞ -шаре; ϵ – бюджет допустимых модификаций.

PGD – итеративный FGSM с проекцией обратно в ϵ -шар; базовая эталонная атака.

Не магия – FGSM – это chain rule, направленный на вход; новый адресат градиента, не новый метод.



БЛОК 3.3

3.3

Что противник знает о модели

Сила атаки зависит от того, что атакующему известно. Разберём три уровня доступа – white-, gray- и black-box – и явление переносимости: почему возмущение, найденное на одной модели, часто срабатывает и против другой.



Три уровня доступа противника

White-box, gray-box, black-box – на концептуальном уровне

Чтобы оценить реальную опасность, нужно сначала задать допущение: что именно противник знает о модели. Принято выделять три уровня.

WHITE-BOX

Полный доступ

Известны архитектура, веса и градиенты. Можно считать $\nabla_x L$ напрямую – FGSM/PGD применимы «в лоб».

GRAY-BOX

Частичный доступ

Известно что-то одно: тип модели, часть признаков или обучающие данные – но не всё сразу.

BLACK-BOX

Только ответы

Виден лишь выход модели на поданный вход. Градиента нет; атака идёт через запросы или перенос.



Что меняется с уровнем доступа

Чем меньше известно противнику, тем дороже атака – но не невозможнее

Уровень доступа определяет реалистичность сценария и стоимость атаки. White-box – самый пессимистичный случай: его берут как «худший возможный» при аудите. Black-box ближе к внешнему злоумышленнику, но не безопасен: атаку строят запросами или переносом.

УРОВЕНЬ	КАК СТРОИТСЯ АТАКА	ТИПИЧНЫЙ СЦЕНАРИЙ
White-box	Прямой расчёт $\nabla_x L$	Оценка худшего случая, аудит надёжности
Gray-box	Догадки + частичные данные	Реалистичный инсайдер или утечка деталей
Black-box	Запросы к API или перенос атаки	Внешний злоумышленник без доступа внутрь



Переносимость атак (transferability)

Почему black-box опаснее, чем кажется

ОПРЕДЕЛЕНИЕ

Переносимость (transferability) – свойство adversarial-возмущений срабатывать не только против той модели, на которой они найдены, но и против других моделей, обученных на похожих данных для той же задачи.

Почему это важно для защиты. Переносимость превращает black-box в white-box-«через посредника». Противник без доступа к вашей модели обучает собственную суррогатную модель на похожих данных, строит возмущение против неё (где у него полный доступ) – и переносит его на вашу. Поэтому «модель закрыта, градиента не видно» не означает «модель защищена»: атаку можно подготовить в стороне.

Суррогатная модель → возмущение на ней → перенос на закрытую модель-жертву.



Где это видно: разные модальности

Один механизм – изображения, тексты, табличные признаки

Состязательные возмущения проявляются во всех модальностях, потому что механизм один – градиент по входу. Меняется лишь то, что считать «малым допустимым изменением».

Изображения

Незаметный сдвиг пикселей меняет класс. Это классическая демонстрация adversarial. Общая структура CV – в L14.

Тексты и URL

Замена символов, синонимы, невидимые вставки обходят фильтр. Adversarial для текстов – в L15; prompt injection – прикладная сторона LLM в L16.

Табличные признаки

Сдвиг признаков соединения в пределах допустимого уводит детектор (как в примере на CIC-IDS-2018).



Мини-резюме: доступ и перенос

Блок 3.3 – модель угроз становится конкретнее

Три уровня доступа – white-box (всё известно) → gray-box (часть) → black-box (только ответы).

Доступ задаёт сценарий – white-box – для оценки худшего случая; black-box – для внешнего злоумышленника.

Переносимость – возмущение с одной модели срабатывает на другой, обученной на похожих данных.

Закрытость ≠ защита – через суррогатную модель и перенос атака возможна и без доступа к градиенту.

Механизм один – во всех модальностях это градиент по входу; различается лишь «допустимое» δ .



БЛОК 3.4

3.4

Меры снижения риска

Что делать с adversarial-риском – и чего ждать не стоит. Разберём adversarial training и его пределы, системные меры за пределами одной модели и threat modeling для ML. Главный вывод: универсальной «серебряной пули» не существует.



Adversarial training и его пределы

Самая прямая защита – и почему её недостаточно

Идея. Самый прямой ответ на атаку – обучать модель на самих adversarial-примерах. В процессе обучения к объектам добавляют возмущения (например, PGD) и заставляют модель давать правильный ответ на них. Модель учится быть устойчивой к возмущениям, которые видела.

ЧТО ДАЁТ

- Повышает устойчивость к знакомым атакам
- Концептуально простой приём
- Базовая линия защиты

ПРЕДЕЛЫ

- Защищает в основном от виденных атак
- Дороже обучение, часто падает обычная точность
- Новая, более сильная атака может обойти

Adversarial training сдвигает планку, но не закрывает проблему: это улучшение, а не гарантия.



Частая ошибка: «одна защита решает всё»

Поиск «серебряной пули» – главная стратегическая ошибка

⚠ ЧАСТАЯ ОШИБКА

«Применили adversarial training (или любую одну защитную технику) – значит, проблема adversarial-атак закрыта, модель защищена».

ПОЧЕМУ ЭТО НЕВЕРНО

Серебряной пули нет. Каждая отдельная защита закрывает свой класс атак и обходится новой, заточенной под неё – это гонка брони и снаряда, а не разовое решение. Реальная устойчивость рождается из комбинации мер (ML- и не-ML-уровня), выстроенных так, чтобы обход одной не означал провал всей системы. Защита – свойство архитектуры, а не галочка «применили метод X».

Вывод «у нас стоит защита X» без модели угроз и проверки – это иллюзия безопасности.



Системные меры защиты

Устойчивость за пределами одной модели – комбинация, а не одна техника

Раз одной модели недостаточно, риск снижают на уровне всей системы. Эти меры дополняют друг друга: каждая закрывает свой угол, а вместе они повышают цену успешной атаки.

Feature hardening

Использовать признаки, которые противнику трудно менять, не разрушив сам объект.

Ансамбли проверок

Несколько независимых детекторов и правил – обход одного не означает обход всех.

Контроль confidence

Отслеживать уверенность и входы у границы решения; низкая уверенность → не доверять автоматически.

Fallback и limit

Подозрительное – на ручную проверку; ограничить автоматизацию необратимых действий.



Threat modeling для ML-компонента

Вводим сквозной термин курса – он понадобится в L19 и L20

ОПРЕДЕЛЕНИЕ

Threat modeling для ML – систематический разбор того, кто, зачем и как может атаковать ML-компонент: какие у противника цели и доступ, какие входы он контролирует, что он может изменить и какие последствия это несёт для всей системы.

Зачем это нужно. Нельзя осмысленно защищаться, не ответив сначала на вопрос «от кого и от чего». Threat modeling переводит разговор от «применим защиту X» к «какие угрозы реальны для нашей системы и какие меры их покрывают». Это вторая компонента модели угроз ML – рядом с drift из L17. В L19 (poisoning) и L20 (итоговая оценка) термин используется уже без переопределения.



Мини-резюме: меры и пределы

Блок 3.4 – конец основного содержания

Adversarial training – обучение на возмущённых примерах; помогает против знакомых атак, но не гарантия.

Нет серебряной пули – любая одна защита обходится; устойчивость – это комбинация ML- и не-ML-мер.

Системные меры – feature hardening, ансамбли проверок, контроль confidence, fallback и лимиты автоматизации.

Threat modeling для ML – сначала «от кого и от чего», потом меры; сквозной термин курса (далее L19, L20).

Защита – свойство системы – не галочка «метод X», а архитектура, где обход одной меры не рушит всё.



ЧАСТЬ 4

Связки с практикой ИБ

Теория разобрана. Теперь – как состязательные воздействия выглядят в реальных задачах информационной безопасности: развёрнутые кейсы с числами, особенности ИБ-данных и ответственная рамка работы с adversarial-рисками.



ИБ-кейс: уклонение детектора

Развёрнутый разбор на CIC-IDS-2018 с числами

ИБ-КЕЙС · CIC-IDS-2018

Детектор на CIC-IDS-2018 ловит DoS-соединения: на тесте precision 0.97, recall 0.94. Атакующий хочет провести DoS так, чтобы детектор счёл соединение нормальным (Benign), не ломая саму атаку – меняя только наблюдаемые признаки потока.

ПРИЗНАК ПОТОКА	БЫЛО	СТАЛО	ДОПУСТИМО?
Длительность потока (с)	0.8	3.5	да – добавлены паузы
Число пакетов	120	240	да – трафик раздроблен
Полезная нагрузка	DoS	DoS	не менялась

Итог. Признаки сдвинуты в пределах работающей атаки, но вектор перешёл границу решения: на этом соединении recall детектора падает до нуля – DoS проходит как Benign. Сама атака не изменилась.



ИБ-кейс: обход текстового фильтра

Та же идея уклонения – на другой модальности

Фильтр блокирует фишинговые письма и вредоносные URL по тексту. Противник не меняет смысл сообщения для человека, но меняет его так, чтобы модель перестала видеть угрозу.

Замена символов

Похожие по виду буквы (латиница/кириллица), вставка точек и дефисов в URL.

Перефразирование

Синонимы и переформулировки обходят сигнатуры, сохраняя смысл для жертвы.

Невидимые вставки

Нулевой ширины символы и разметка, незаметные человеку, ломают токенизацию.

Цель часто скромнее «полного обхода»: достаточно попасть из автоблокировки в очередь ручной проверки.



Чем особенны ИБ-данные здесь

Почему adversarial-риск в безопасности острее, чем в среднем ML

Активный, адаптивный противник — Он наблюдает реакции и подстраивается под логику модели — в отличие от статичной природы из L17.

Защита сама — цель атаки — Чем важнее модель в контуре безопасности, тем выгоднее её обойти.

Автоматическое доверие = риск — Решение без второй проверки превращает один обман модели в успешное вторжение.

Опасность задаёт не модель, а система — Реальный риск зависит от архитектуры вокруг модели, а не только от её уязвимости.



Частая ошибка: вывод без threat modeling

«Модель точна – значит, система защищена»

⚠ ЧАСТАЯ ОШИБКА

«На тесте precision и recall высокие, метрики отличные – значит, детектор надёжен и систему можно полностью автоматизировать».

Чего здесь не хватает. Вывод об устойчивости сделан без модели угроз. Метрики на обычном тесте описывают средний случай и ничего не говорят о поведении против противника. Прежде чем доверять модели автоматическое решение, нужно ответить: кто может атаковать, какой у него доступ, какие входы он контролирует, что будет при обходе. Без этого «отличные метрики» – ложное чувство защищённости.

Сначала threat modeling (L18), потом вывод об устойчивости – не наоборот.



Ответственная рамка исследования

Понимать риск – не значит атаковать действующие системы

Цель этой лекции – понять природу adversarial-риска и научиться защищаться, а не получить инструкцию для атак. Это различие критично и профессионально, и юридически.

ОБРАЗОВАТЕЛЬНАЯ ЦЕЛЬ

- Понимать механизм риска
- Оценивать устойчивость своих моделей
- Проектировать защитные меры

КАТЕГОРИЧЕСКИ НЕЛЬЗЯ

- Атаковать чужие действующие системы
- Применять это против реальных сервисов
- Воспринимать лекцию как offensive-руководство

Демонстрация уязвимости в учебной среде и эксплуатация боевой системы – разные вещи и по смыслу, и по ответственности.



Главное из лекции

Семь ключевых утверждений

- 1 Модель ошибается не только от шума – есть противник, целенаправленно меняющий вход.
- 2 Состязательное возмущение – малое намеренное δ в ϵ -окрестности; не шум, а оптимизация против модели.
- 3 FGSM: $x' = x + \epsilon \cdot \text{sign}(\nabla_x L)$ – тот же градиент, что в обучении, но по входу и вдоль роста потери.
- 4 PGD – итеративный FGSM с проекцией в ϵ -шар; базовая эталонная атака.
- 5 Закрытость модели не равна защите: переносимость позволяет атаковать через суррогат.
- 6 Серебряной пули нет – устойчивость даёт комбинация ML- и не-ML-мер.
- 7 Сначала threat modeling, потом вывод об устойчивости – не наоборот.



Где это нужно, где переоценено

Когда adversarial-анализ оправдан, а когда отвлекает

Adversarial-устойчивость – не самоцель, а функция модели угроз. Стоит соизмерять усилия с тем, есть ли реальный заинтересованный противник и какова цена его успеха.

НУЖНО УЧИТЫВАТЬ

- Детекторы вторжений, фрод, спам-фильтры
- Антивирусные и URL-классификаторы
- Любая модель в контуре безопасности с автоматическим решением
- Везде, где есть заинтересованный противник

ЧАСТО ПЕРЕОЦЕНЕНО

- Задачи без противника (прогноз, рекомендации)
- Когда вход неподконтролен атакующему
- Погоня за стойкостью в ущерб обычной точности без обоснования
- Демонстрации «на картинках» без связи с системой



Граница с L19: evasion vs poisoning

Обязательное различие двух классов атак

И evasion, и poisoning – состязательные воздействия, но они бьют в разные точки жизненного цикла модели. Смешивать их – типовая ошибка; вот чёткая граница.

EVASION · L18 (ЭТА ЛЕКЦИЯ)

- Когда: на инференсе, модель готова
- Что трогает: только вход объекта
- Цель: обмануть на конкретном входе
- Пример: подвинуть признаки потока

POISONING · L19 (СЛЕДУЮЩАЯ)

- Когда: на обучении или в артефактах
- Что трогает: обучающие данные / модель
- Цель: испортить саму модель заранее
- Пример: подмешать вредоносные примеры

Коротко: evasion обманывает готовую модель на входе; poisoning портит модель до её применения. Подробнее – L19.



Связь с курсом: куда дальше

Как L18 встроена в сквозные линии курса

Threat modeling для ML

L17 (drift) → **L18 (evasion)** → L19 (poisoning) → L20 (итоговая оценка)

Модель как компонент системы

L03 → L07 → L16 → **L18** → L20

Что читать дальше. L19 завершает модель угроз со стороны обучающих данных (poisoning, backdoor, supply-chain), а L20 сводит всё в итоговый reliability/security note. Термин «threat modeling для ML», введённый здесь, в обеих лекциях используется без переопределения.



Источники: обязательное

Базовое чтение по теме лекции

Goodfellow, Shlens, Szegedy (2015)

«Explaining and Harnessing Adversarial Examples», ICLR 2015 (arXiv:1412.6572). Первоисточник FGSM.

Madry, Makelov, Schmidt, Tsipras, Vladu (2018)

«Towards Deep Learning Models Resistant to Adversarial Attacks», ICLR 2018 (arXiv:1706.06083). PGD и adversarial training.

Goodfellow, Bengio, Courville (2016)

«Deep Learning», MIT Press – гл. 6 (обратное распространение) и гл. 7 (регуляризация) как база для понимания градиента.



Источники: дополнительно

Для углубления и практики

Для углубления

- Papernot et al. – работы по transferability и black-box атакам (обзор переносимости).
- Carlini & Wagner (2017) – более сильные атаки (C&W); за рамками курса, но полезно знать о существовании.
- Joseph, Nelson, Rubinstein, Tygar «Adversarial Machine Learning» – системный взгляд на угрозы ML.

Практика и данные

- Тьюториалы по adversarial robustness (документация PyTorch / библиотека на ваш выбор).
- CIC-IDS-2018 – площадка для собственных экспериментов с уклонением по табличным признакам.



Глоссарий (1 из 2)

Ключевые термины

Adversarial perturbation	малое намеренное δ входа в ϵ -окрестности, меняющее предсказание модели
Evasion	воздействие на вход на этапе инференса с целью обмануть готовую модель
FGSM	$x' = x + \epsilon \cdot \text{sign}(\nabla_x L)$ – одношаговое возмущение по знаку градиента потери
ϵ-окрестность (ϵ-шар)	область допустимых изменений входа; бюджет возмущения по норме L^∞/L_2
$\text{sign}(\nabla_x L)$	знак градиента потери по входу: фиксированный шаг ± 1 по каждой координате
PGD	итеративный FGSM с проекцией обратно в ϵ -шар; базовая эталонная атака
Adversarial training	обучение на возмущённых примерах для повышения устойчивости



Глоссарий (2 из 2)

Ключевые термины

White/gray/black-box	уровни доступа противника: всё известно / частично / только ответы
Transferability	перенос возмущения с одной модели на другую, обученную на похожих данных
Суррогатная модель	своя модель противника для подготовки атаки и последующего переноса
Feature hardening	выбор признаков, которые трудно менять, не разрушив сам объект
Threat modeling для ML	разбор: кто, зачем и как может атаковать ML-компонент системы
Fallback / confidence	перевод подозрительного на проверку; контроль уверенности модели
Evasion vs poisoning	обман готовой модели на входе (L18) vs порча модели на обучении (L19)